BOOSTHUB STAKING V2

Independent-review process / Sealed August 23, 2026

FINAL SECURITY VERDICT

PASS

Seven validated Low-severity findings

Four verified fixes / Three accepted residual risks

8	114	0
SOURCE FILES REVIEWED	ENTRYPOINTS REVIEWED	MEDIUM / HIGH / CRITICAL

Scope: audited smart contracts only. No production deployment attestation is claimed.

This release links seven selected public evidence files; the source ZIP is not published.

Executive summary

THE CONTRACT SYSTEM AND WHAT IT DOES

This five-contract suite connects a depositor-facing Vault to a staking Strategy, a Vyper staking layer and the external BoostHub system. It handles principal, withdrawals, reward accrual and conversion for sdCRV, sdFXN and sdYB pool configurations. A governance token controls bounded incentive issuance.

CurveYieldVault	Holds depositor-facing share accounting and redemption claims. Its share pricing can include the Strategy's estimate of unharvested rewards.
CurveYieldStakingStrategyV2	Moves Vault assets into staking, orchestrates harvest and reward conversion, and controls specified rescue and ChildGauge pathways.
BoostHubStaking v17	Vyper staking adapter between the Strategy and BoostHub, handling stake state, reward distribution, fees and withdrawal timing.
SdYbRewardConverter	Implements sdYB-oriented conversion quotes and execution through external liquidity routes used in reward accounting.
CurveYieldGovernanceToken	Manages cyGOV supply, bounded minter allocations, owner privileges and transfer restrictions for governance incentives.

FINDINGS, REPAIRS AND WHAT REMAINS

Seven Low-severity findings were validated. Four vulnerabilities were repaired and independently re-tested; three bounded, Low-severity economic risks remain expressly accepted. No Critical, High or Medium findings were validated.

4 FIXED / VERIFIED

Converter pricing and executable tolerance were corrected; the stale reward-rescue timer was reset on reactivation; and sdYB WANT/native reward classification was repaired.

3 ACCEPTED LOW RISKS

The remaining risks involve marginal reward-preview effects on share issuance, privileged rescue of disabled reward balances, and reward carry stranded after disablement.

Smart-contract scope and exclusions

Public evidence provenance

Audit footprint

CODEBASE

5 Implementations reviewed	**3** Interfaces examined	**8** Audited source files	**2** Source languages
114 Reviewed entrypoints	**9** Authority actor categories	**7** Protected capital classes	**6** Documented trust boundaries

ARCHITECTURE AND SCOPE

17 Mapped asset-flow edges	**10** Assessed security domains	**6** Applicable security domains	**1** External staking platform
0 Cross-chain domains	**0** Upgrade-proxy domains	**0** Lending domains	**0** Signature-specific domains

Depth of security investigation

THREAT ANALYSIS

26 Positive security requirements	**22** Negative security requirements	**28** Specified invariants	**10** Modeled threat scenarios
23 Attack-tree branches	**7** Critical invariant families	**130** Neutral Slither observations	**114** Entrypoints manually reviewed

VALIDATION AND EXECUTION

9 Substantive candidates	**9** Candidates dispositioned	**2** Dismissed candidates	**0** Inconclusive candidates
6 Dynamically evidenced candidates	**7** Validated security findings	**4** Verified remediations	**3** Accepted residual findings

Findings and resolution

7 LOW

No validated Critical, High or Medium findings

4	3
FIXED / VERIFIED	ACCEPTED LOW

VALIDATED FINDING SEVERITY

CANDIDATE DISPOSITION

Promoted to validated findings	7
Dismissed after assessment	2
Remaining inconclusive	0

System architecture and trust

Canonical principal-flow model; arrows describe accepted high-level interactions.

Principal and shareholder accounting

Deposits and redemptions flow through the Vault and Strategy; the staking system manages withdrawal queues and reward liability.

Reward conversion and price sensitivity

External Curve-style liquidity and quote paths affect reward conversion and estimated unharvested values. The remediated converter enforces oracle-aware tolerance.

Privileged control boundaries

Token minting, fee and reward configuration, rescue delays, and staking configuration are controlled by distinct authority roles.

Independent external dependencies

BoostHub, ERC-20 assets, reward converters, Curve pools and ChildGauge integrations introduce external liveness or trust assumptions.

Adversarial verification

01

Medusa fuzzing

The recorded Medusa terminal campaign tested source-bound security behavior and produced a decisive candidate reproduction.

02

Native fuzz execution

Foundry native fuzzing was invoked after Medusa; the recorded 10,000-run requested budget found a counterexample to the deposit property.

03

Deterministic candidates

Six carried candidate mechanisms received dynamic execution evidence during Phase 6; this does not imply six validated vulnerabilities.

04

Pinned Ethereum fork

Phase 7 exercised staking, harvest, withdrawal, conversion and reward behavior on a pinned Ethereum fork, including sdCRV, sdFXN and sdYB paths.

05

Independent remediation verification

Phase 9 recorded four independently verified remediations, including executable converter routes, stale rescue timer, sdYB classification and tolerance bounds.

LOW-SEVERITY SECURITY FINDINGS

Four fixed-size boxes per severity page. Open slots remain blank.

BH-V2-LOW-001

ACCEPTED RESIDUAL

Vault reward-preview valuation can marginally affect share issuance

DESCRIPTION

The Vault's standard-deposit accounting can allow a new depositor to receive a marginal share advantage when the value attributed to already-accrued but unharvested rewards is temporarily depressed. Pinned-fork testing reproduced the effect, but the demonstrated economic impact was very small and no scalable profitable extraction loop was established.

SECURITY IMPACT Marginal share-issuance advantage from temporary reward valuation distortion.

Finding details, impact and disposition verified in the public findings record

BH-V2-LOW-002

FIXED / VERIFIED

Converter fair-value / execution protection

DESCRIPTION

The original conversion design could use insufficiently independent market-derived values for conversion protection, allowing reachable reward-processing liveness failures under adverse market conditions.

SECURITY IMPACT Conversion protection could cause harvest-liveness failure during price divergence.

Finding details, impact and disposition verified in the public findings record

BH-V2-LOW-003

ACCEPTED RESIDUAL

Disabled reward-route balances can become owner-rescuable

DESCRIPTION

After a reward route is disabled and the contractual rescue delay completes, reward-token balances held by the Strategy can become rescuable by the privileged owner. The behavior is limited to reward-token value, requires privileged action, and does not expose deposited principal.

SECURITY IMPACT Privileged owner may rescue disabled-route reward-token balances after delay.

Finding details, impact and disposition verified in the public findings record

BH-V2-LOW-004

ACCEPTED RESIDUAL

Residual reward carry can become stranded after reward disablement

DESCRIPTION

A residual reward_remaining balance can remain recoverable while the reward remains enabled, but disabling the reward can remove the later rescheduling path that otherwise distributes that carry. The condition requires the relevant reward-state sequence and does not affect deposited principal.

SECURITY IMPACT Disabled reward route may prevent later distribution of residual carry.

Finding details, impact and disposition verified in the public findings record

LOW-SEVERITY SECURITY FINDINGS

Four fixed-size boxes per severity page. Open slots remain blank.

BH-V2-LOW-005

FIXED / VERIFIED

Stale rescue-timer pre-aging

DESCRIPTION

The original Strategy could retain an old tokenRescueReadyAt timestamp across reward-route re-enablement, allowing a later disable/rescue cycle to inherit a previously matured timer instead of receiving a fresh delay.

SECURITY IMPACT Pre-aged rescue timer could bypass a fresh warning interval.

Finding details, impact and disposition verified in the public findings record

BH-V2-LOW-006

FIXED / VERIFIED

sdYB WANT / BoostHub-native reward classification incompatibility

DESCRIPTION

The original staking constructor could incorrectly require the configured WANT to also be registered as a BoostHub-native reward. For the sdYB pool, this prevented the intended staking contract construction because sdYB is the WANT but is not a native BoostHub reward token.

SECURITY IMPACT Incorrect WANT classification could block sdYB staking construction.

Finding details, impact and disposition verified in the public findings record

BH-V2-RR2-LOW-001

FIXED / VERIFIED

Exact oracle preview used as staking fee-conversion minOut

DESCRIPTION

The first remediation round corrected converter pricing but left the staking contract passing its oracle-derived preview as an exact minimum output. Normal oracle-versus-executable-price divergence could therefore revert fee conversion even without a security-significant price anomaly.

SECURITY IMPACT Exact oracle preview as minOut could revert otherwise normal fee conversions.

Finding details, impact and disposition verified in the public findings record

Remediation and residual risk

FOUR INDEPENDENTLY VERIFIED FIXES

BH-V2-LOW-002	Converter fair-value / execution protection
BH-V2-LOW-005	Stale rescue-timer pre-aging
BH-V2-LOW-006	sdYB WANT / BoostHub-native reward classification incompatibility
BH-V2-RR2-LOW-001	Exact oracle preview used as staking fee-conversion minOut

THREE EXPRESSLY ACCEPTED LOW FINDINGS

BH-V2-LOW-001	Vault reward-preview valuation can marginally affect share issuance
BH-V2-LOW-003	Disabled reward-route balances can become owner-rescuable
BH-V2-LOW-004	Residual reward carry can become stranded after reward disablement

These accepted issues remain unfixed. They are documented as marginal, bounded economic impact, not as eliminated risk. Further code or configuration changes require their own source-bound review before any equivalence to this audit may be claimed.